

Unit 1 - Introduction of Information & Network Security

Cryptography and Web Security (DI03016021) - GTU Diploma IT Sem 3

18% weightage | 9 hours

How to use these notes: each topic is written the way you can copy it in the exam. For a **3-mark** question write only the definition + 2-3 points. For **4 marks** add an example or table. For **7 marks** write everything, with diagram and table. Lines marked ★ show where the topic was already asked in a GTU paper (only 2 papers exist so far: Winter 2025 and Summer 2026).

Questions already asked from this unit (do these first)

- Asked in BOTH papers: W2025 Q1(a) [3M] + S2026 Q2(a) [3M]
- Asked in BOTH papers: W2025 Q2(c)OR [7M: two passive + four active] + S2026 Q1(c) [7M: classify + any three active]
- Asked in W2025 Q2(c) [7M: six security services in detail]
- Asked in S2026 Q2(a)OR [3M: any three security mechanisms]
- Asked in BOTH papers: W2025 Q2(b) [4M] + S2026 Q1(c)OR [7M]
- Asked in S2026 Q1(a) [3M: define cryptography and cryptanalysis]

1.1 Computer, Cyber, Information and Network Security

These four words look similar but have different **scope** (how wide the protection is).

Term	Simple meaning	Example
Computer security	Protecting one computer: its hardware, software and data	Antivirus, login password on your PC
Cyber security	Protecting systems, networks and data from attacks that come through the internet / cyberspace	Stopping hackers, phishing, ransomware
Information security	Protecting <i>information</i> in any form (digital or paper) from misuse. Based on CIA	Locking files, encrypting a database, shredding papers
Network security	Protecting data while it travels over the network and protecting network devices	Firewall, IDS, VPN, SSL/TLS

1.2 Security requirements: Confidentiality, Integrity, Availability, Authenticity, Accountability

★ Asked in BOTH papers: W2025 Q1(a) [3M] + S2026 Q2(a) [3M]

CIA triad = the three main goals of computer security.

Goal	Meaning (simple)	Example	How we get it
Confidentiality	Only authorised people can read the information. Keep it secret.	ATM PIN, encrypted chat	Encryption, passwords
Integrity	Information is not changed by unauthorised people. Keep it the same.	Hacker changes Rs.1,000 to Rs.10,000 in a bank record = integrity lost	Hash, digital signature, checksum
Availability	Data and services are available whenever authorised users need them. Keep it running.	Website crashing due to a DoS attack = availability lost	Backup, redundancy, firewall

Two extra requirements (for 4-7 marks):

- **Authenticity** - the message/user is genuine and can be verified (it really came from who it says).
- **Accountability** - every action can be traced to the person who did it (logs), so nobody can deny it later.

Easy way to remember: Confidentiality = **Secret**, Integrity = **Same (unchanged)**, Availability = **Always on**.

1.3 The OSI Security Architecture

The **OSI Security Architecture** (ITU-T recommendation **X.800**) gives a systematic way to define security needs. It is built around three things:

Part	Meaning	Easy line
Security attack	Any action that compromises the security of information	What the enemy does
Security mechanism	A tool/process to detect, prevent or recover from an attack	The tool we use
Security service	A service that improves the security of data processing and transfer, using mechanisms	What the system promises

1.4 Security Attacks: Passive and Active

★ Asked in BOTH papers: W2025 Q2(c)OR [7M: two passive + four active] + S2026 Q1(c) [7M: classify + any three active]

Security Attacks

PASSIVE attacks
Release of message contents
Traffic analysis

ACTIVE attacks
Masquerade | Replay
Modification | Denial of Service

A) Passive attacks - attacker only *watches*, does not change anything

- **Release of message contents:** attacker reads (eavesdrops) an email, phone call or file.
Example: sniffing an unencrypted Wi-Fi password.
- **Traffic analysis:** even if the message is encrypted, attacker studies the pattern - who talks to whom, how often, message length - and guesses useful information.

Passive attacks are **very hard to detect** (nothing changes) but **can be prevented** by encryption.

B) Active attacks - attacker *changes* data or disturbs the system

- **Masquerade:** one entity pretends to be another. *Example: using a stolen password to log in as someone else.*
- **Replay:** attacker captures a valid message and sends it again later to get an unauthorised effect. *Example: re-sending a captured 'transfer Rs.5,000' request.*
- **Modification of messages:** part of a genuine message is altered, delayed or reordered. *Example: 'Pay Rs.100 to A' changed to 'Pay Rs.900 to B'.*
- **Denial of Service (DoS):** attacker floods a server or network so genuine users cannot use it. *Example: millions of fake requests crash a website.*

Active attacks are **easy to detect** but **hard to prevent completely** - so we try to detect and recover.

Point	Passive attack	Active attack
Data	Not altered	Altered or created
Goal	Learn information	Damage / change / disturb
Detection	Very difficult	Easier
Prevention	Possible (encryption)	Difficult (detect + recover)
Threatens	Confidentiality	Integrity, Availability, Authenticity

Exam tip: For '7 marks' draw the classification diagram, write 2 passive + 4 active with one example each, and add the comparison table.

1.5 Security Services

★ Asked in W2025 Q2(c) [7M: six security services in detail]

A **security service** is what a system provides to protect data. X.800 defines these six:

Service	What it does	Example
1. Authentication	Confirms that the user/message is genuine. Two types: <i>peer-entity</i> (who is on the other side) and <i>data-origin</i> (who sent this data).	Login with ID + password / OTP
2. Access control	Decides <i>who</i> can use <i>which</i> resource and what they can do with it (read, write, delete).	Student can read marks, only teacher can edit
3. Data confidentiality	Protects data from unauthorised reading. Types: connection, connectionless, selective-field, traffic-flow confidentiality.	Encrypting an email or file
4. Data integrity	Makes sure data is received exactly as sent - no change, insertion, deletion or replay.	Hash/checksum of a downloaded file
5. Nonrepudiation	Sender cannot deny sending and receiver cannot deny receiving. Origin and destination types.	Digital signature on an online contract
6. Availability service	Keeps resources usable when authorised users need them, even under attack.	Backup servers, firewall against DoS

Easy way to remember: A-A-C-I-N-A: Authentication, Access control, Confidentiality, Integrity, Nonrepudiation, Availability.

1.6 Security Mechanisms

★ Asked in S2026 Q2(a)OR [3M: any three security mechanisms]

A **security mechanism** is a method/tool used to detect, prevent or recover from an attack. There are two groups:

Specific security mechanisms (used in a particular protocol layer / service)

- **Encipherment:** converting data into unreadable form using algorithms and keys.

- **Digital signature:** data added to a message that proves who sent it and that it was not changed.
- **Access control:** methods that enforce who can use which resource.
- **Data integrity:** checks (hash/checksum) that data was not altered.
- **Authentication exchange:** two parties exchange information to prove their identity.
- **Traffic padding:** inserting fake bits so traffic analysis is difficult.
- **Routing control:** choosing physically secure routes for sensitive data.
- **Notarization:** a trusted third party guarantees properties of the data exchange.

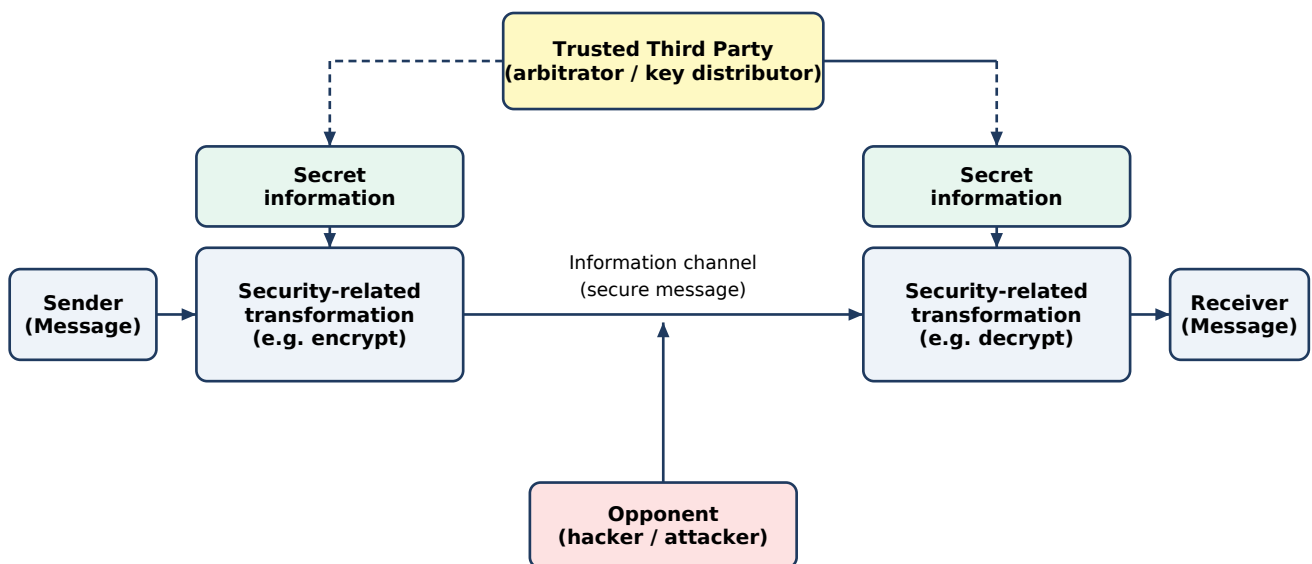
Pervasive security mechanisms (not tied to one service or layer)

- **Trusted functionality:** a function that is considered correct and trusted.
- **Security label:** marking of a resource (e.g. 'Confidential', 'Secret').
- **Event detection:** detecting security-related events.
- **Security audit trail:** records of events kept for later review.
- **Security recovery:** actions taken to recover after an attack.

Exam tip: For a 3-mark 'any three' question just write three specific mechanisms with one line each, as above.

1.7 Model for Network Security

★ Asked in BOTH papers: W2025 Q2(b) [4M] + S2026 Q1(c)OR [7M]



Explanation: A message must travel from the **sender** to the **receiver** over an **information channel** (internet). An **opponent** may attack this channel. So a **security-related transformation** is applied:

- At the sender: the message is transformed (e.g. **encrypted**) using **secret information** (a key), so it becomes unreadable for the opponent.
- At the receiver: the reverse transformation (e.g. **decryption**) is done using the secret information to get the original message.
- A **trusted third party** may be needed to distribute the secret information (keys) or to settle disputes between sender and receiver.

Four tasks while designing a security service (for 7 marks)

1. Design an **algorithm** for the security transformation that is hard for an opponent to break.
2. **Generate the secret information** (keys) to be used with the algorithm.
3. Develop methods for **distribution and sharing** of the secret information.

4. Specify a **protocol** that uses the algorithm and secret information to provide the security service.

Exam tip: 4 marks: diagram + 3-4 lines. 7 marks: diagram + explanation + the four design tasks.

1.8 Cryptography: Concept and Classification

★ Asked in S2026 Q1(a) [3M: define cryptography and cryptanalysis]

- **Cryptography:** the science and art of keeping information secret by converting **plaintext** (readable) into **ciphertext** (unreadable) using algorithms and keys, and converting it back. *Example: HELLO → KHOOR (shift by 3).*
- **Cryptanalysis:** the science of **breaking** ciphers, i.e. finding the plaintext or the key from ciphertext **without** knowing the key. *Example: trying all keys (brute force) or using letter-frequency analysis.*
- **Cryptology** = Cryptography + Cryptanalysis.

Classification of cryptographic algorithms (syllabus 1.8)

Cryptography

Keyless
(no key)

Single-key
(symmetric)

Two-key
(asymmetric)

Type	Key used	Examples
Keyless	No key at all	Hash functions (SHA, MD5), pseudo-random generators
Single-key (symmetric)	Same secret key for encryption and decryption	Caesar, Vigenère, DES, AES
Two-key (asymmetric)	Public key encrypts, private key decrypts (or vice versa)	RSA, ECC, Diffie-Hellman

Last-minute revision sheet - Unit 1

- CIA = Confidentiality (secret), Integrity (unchanged), Availability (always on). Extra: Authenticity, Accountability.
- Passive attacks: release of message contents, traffic analysis. Active: masquerade, replay, modification, DoS.
- Six services: Authentication, Access control, Data confidentiality, Data integrity, Nonrepudiation, Availability.
- Mechanisms: 8 specific (encipherment, digital signature, access control, data integrity, authentication exchange, traffic padding, routing control, notarization) + 5 pervasive (trusted functionality, security label, event detection, audit trail, recovery).
- Network security model = sender + transformation + channel + transformation + receiver, with trusted third party and opponent. Four design tasks.
- Cryptography types: keyless (hash), single-key (symmetric), two-key (asymmetric).